# Natalyx MVP Fixes

Work Package 13: Deployment, cloud gates, and PHI readiness

L. Rhodes (plan owner) - A. Zhao (technical feedback reconciled)

2026-07-12

# Contents

**1 Work Package 13: Deployment, cloud gates, and PHI readiness** **2**

1.1 Purpose and outcome . . . . . 2

1.2 Verified current-state evidence . . . . . 3

1.3 Architecture and contracts . . . . . 4

1.4 Explicit PR sequence . . . . . 9

1.5 Cross-repository coordination . . . . . 29

1.6 Test and acceptance matrix . . . . . 30

1.7 Risks and decisions . . . . . 31

1.8 Existing-work salvage . . . . . 34

1.9 Ownership recommendation . . . . . 35

1.10 Definition of done . . . . . 37

# 1 Work Package 13: Deployment, cloud gates, and PHI readiness

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

| Plan | Value |
|---|---|
| Work package | WP13 |
| Plan file | `WP13 - Deployment, cloud gates, and PHI readiness.md` |
| Proposed PRs | P13-01, P13-02, P13-03, P13-04, P13-05, P13-06, P13-07 |
| Inspection snapshot | 2026-07-12 19:30 America/New_York |

## 1.1 Purpose and outcome

**Problem.** The dev endpoint is presently 503, deployments do not prove application readiness, and test/deploy success cannot establish real-user or PHI readiness.

**Why this package exists.** It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

**Completed outcome.** Known-revision diagnostics, guarded rollback/evidence capture, automated synthetic A1/A2 journeys, and explicit B1/B2 operational/privacy/PHI go/no-go packets.

**Explicit non-goals.**

- No deployment in this planning task

- No real user before B1
- No PHI before B2
- No compliance claim from green CI

## 1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

| ID | Class | Repository / ref | File, construct or location | Finding |
|---|---|---|---|---|
| E-001 | verified | live dev / 2026-07-12 19:30 America/New_York | https://dev.app.natalyx.health/ and /health | Both requests returned HTTP 503 from awselb/2.0; the deployed participant app is not presently usable. |
| E-002 | verified limitation | AWS dev / 2026-07-12 19:30 America/New_York | aws sts get-caller-identity –profile natalyx-dev | Local AWS SSO was expired, so current ECS desired/running counts and task revision were not independently verified. Gate A0 must refresh access and capture them. |
| E-007 | verified | app / feature/byos-node0-consolidation@84a5a84 | app/storage/schema.py:1-33,353-880 | Schema ownership is a monolithic init_db/ensure_column routine with inline CREATE TABLE/ALTER TABLE and no ordered migration/version/checksum ledger. |
| E-008 | verified | app / origin/main@fdf2bb4 | app/main.py:295-313 | Cloud startup validates auth/storage then calls storage.init_db in-process; readiness is not separated from migration execution. |
| E-026 | verified | app / origin/main@fdf2bb4 | app/main.py:145-148 | /healthz returns only status ok when the process can serve; it does not report revision, database, migration, intelligence, storage, or readiness. |
| E-027 | verified | app/infra / origin/main@fdf2bb4 / infra main@fec515f | app .github/workflows/aws-app-deploy.yml:60-190; infra CDK workflow | Deployment reads infra-owned SSM contracts and guards billable ECS updates, but successful image build/contract smoke does not prove a healthy service revision. |
| E-028 | verified review | app / PR #124 comment 4948149089 | Consolidated review - findings for the WP00 extraction ledger | Alan's completed review classifies #124 as high-value extraction material rather than a merge unit and identifies transaction, privacy, scoring, access, validation, invariant, exposure, retention, performance, CSS and CI findings. |

| ID | Class | Repository / ref | File, construct or location | Finding |
|---|---|---|---|---|
| E-030 | independently reproduced defect | app / feat/byos-journey-wave-2@5b63e3a7 | app/storage/schema.py orphan cleanup; document review CAS/work-item payload | A second init_db deletes canonical case-anchored reviewer work because participant_id is empty. Separately, a stale v1 work item can approve v2 after same-row resubmission because it is not bound to an immutable submission revision. |
| E-031 | verified | app / feat/byos-journey-wave-2@5b63e3a7 | case_members.py, case_documents.py, storage/documents.py, routes/agency.py | Membership roles still conflate participation, lens and access; document/reviewer loaders are broad or global; participant role/lens can be caller-supplied; operator actions lack a canonical organization-scoped staff capability; no RLS/non-owner runtime enforces denial. |

## 1.3 Architecture and contracts

- Health, readiness, revision, dependency, migration, and safe configuration signals are distinct.
- Every cloud gate has prerequisites, evidence, owner, verifier, and failure/rollback response.
- B2 requires formal security/privacy/compliance evidence and human go/no-go; it is not a software test result.

| Contract area | Package rule |
|---|---|
| Ownership boundary | `.github`, `app`, `infra`; repository-specific PRs remain separate. |
| Entities/state | No new runtime entity; evidence/coordination only. |
| Authorization | Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority. |
| API/service | Health/readiness endpoints with stable machine-readable reasons. |
| Storage | RLS policies and least-privilege grants under a reviewed migration. |
| Audit | Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads. |
| Failure | Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence. |
| Observability | Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging. |
| Compatibility | Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair. |

| Contract area | Package rule |
|---|---|
| Privacy/PHI | Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2. |

### 1.3.1 Programme gate summary

### 1.3.2 Gate A0 - Infrastructure recovery and known-revision health

| Field | Contract |
|---|---|
| Prerequisite PRs/gates | P01-01, P02-02, P13-01, P13-02 |
| Prerequisite decisions | D-MIG-01, D-CI-01, D-OPS-01 |
| Responsible owner | Alan |
| Verifier | Luke |

Acceptance matrix:

- ☐ GitHub Team is active for NatalyxPlatform; unittest and PostgreSQL checks are mandatory, routine bypass is restricted, and negative-bypass evidence is accepted.
- ☐ Alan's migration ADR records the supported low-maintenance framework, PostgreSQL authority, staged compatibility and the tested recovery path; P02-02/P02-03 evidence passes.
- ☐ CloudFormation/ECS/ALB state is captured from refreshed dev credentials and is stable.
- ☐ The running app and intelligence image SHAs/task definitions are known and map to reviewed commits.
- ☐ Liveness and readiness are both healthy; PostgreSQL, migrations and required private intelligence dependencies pass their bounded checks.
- ☐ A synthetic unauthenticated health request and authenticated minimal route succeed without PII/PHI.
- ☐ The fail-closed recovery runbook is exercised synthetically; the prior compatible image/schema pair is identified and the 30-minute planned-beta recovery target is evidenced.

Required evidence:

- GitHub Team/ruleset readback and negative-bypass result
- Migration ADR and consequential-migration recovery evidence
- AWS account/region and stack/service snapshots
- ALB status and target health
- image SHA/task definition
- readiness JSON/log correlation
- CI/PostgreSQL artifacts
- fail-closed synthetic recovery exercise

**Failure and rollback response.** Do not proceed to participant validation. Freeze live updates, retain evidence, restore the known compatible image/schema or forward-repair under the approved runbook, and keep the programme gate blocked.

### 1.3.3 Gate A1 - Synthetic core participant journey

| Field | Contract |
|---|---|
| Prerequisite PRs/gates | P02-04, P03-01, P03-02, P03-04, P03-05, P04-01, P04-02, P04-03, P05-01, P05-02, P05-03, P11-03, P13-03 |
| Prerequisite decisions | D-AUTH-02, D-DATA-01, D-DATA-02 |
| Responsible owner | Alan |
| Verifier | Luke |

Acceptance matrix:

- ☐ A new synthetic IP signs up, is deterministically routed, enters Node 0 Free and no paid case is created.
- ☐ Candidate/outreach data remains IP-attributed and provisional; no score or answer becomes GC/provider truth.
- ☐ A synthetic GC begins a low-risk claim, binds identity/consent and sees only the allowed workspace projection.
- ☐ Cross-role negative tests prove class-2 IP assertions and class-4 GC-private answers do not leak.
- ☐ The admission proof is short-lived, claim/purpose/email-bound and cannot grant workspace or case membership; replay, mismatch, expiry and revocation fail closed.
- ☐ Both roles log out/in/resume and complete the mobile journey at tested widths.
- ☐ Known revision, audit events, correlation IDs and sanitized evidence are attached to the gate item.

Required evidence:

- A1 synthetic run artifact
- separate IP/GC subject IDs (synthetic only)
- authorization matrix results
- mobile screenshots/accessibility output
- audit event trace
- database invariant queries

**Failure and rollback response.** Stop before Complete, commercial or paid-case validation. Revert/disable the failing participant feature flag or deploy the known A0 revision; preserve synthetic data only for defect diagnosis, then purge under the runbook.

### 1.3.4 Gate A2 - Synthetic commercial, promotion, billing and document journey

| Field | Contract |
|---|---|
| Prerequisite PRs/gates | P03-03, P06-01, P06-02, P06-03, P07-01, P07-02, P07-03, P07-04, P08-01, P08-02, P08-03, P08-04, P09-01, P09-02, P09-03, P09-04, P09-05, P09-06, P10-01, P10-02, P10-03, P10-04, P11-01, P11-02, P11-04, P12-01, P12-02, P13-04 |
| Prerequisite decisions | D-COM-01, D-COM-02, D-COM-03, D-COM-04, D-PAY-01, D-COM-05, D-COM-06, D-COM-07, D-COM-08, D-DOC-01, D-DOC-02, D-PROV-01, D-AI-01 |
| Responsible owner | Alan |
| Verifier | Luke |

Acceptance matrix:

- ☐ Synthetic Complete entitlement does not itself create a case and records its commercial configuration version/credit.
- ☐ Synthetic configuration uses the founder-approved $495 Complete and $8,900 v1 journey schedules, including credits, refunds, loss policy and humane grace behavior; no real charge or live terms acceptance occurs.
- ☐ Only byos.workspace_promotion_authorized.v1 authorizes exactly one enrollment_pending case; callbacks/redirects/replays create none/duplicates.
- ☐ Recipient-bound paid-case invitation and consent grant correct membership; activation waits for approved evidence.
- ☐ Enrollment/activation/milestone/credit/refund ledgers reconcile, including duplicate and out-of-order provider events.
- ☐ Synthetic files follow upload/quarantine/scan/available/download/replacement/revocation/recovery and never become public.
- ☐ Provider packet contains only purpose-allowed consented sources; intelligence scopes and proposals do not upgrade truth.
- ☐ Financing is absent; scanning and AI stay within their $50/month and $100/month beta ceilings with alerts and fail-safe fallback.

Required evidence:

- A2 synthetic run artifact
- processor simulator event ledger
- promotion idempotency query
- invoice/refund explanations
- S3/KMS/IAM/quarantine assertions
- provider snapshot checksum
- Ask/proposal safety evals

**Failure and rollback response.** Disable commercial/document/provider features, retain free/safety content, prevent live money or real documents, reconcile synthetic ledger inconsistencies, and restore the A1-known revision or forward-repair as approved.

### 1.3.5 Gate B1 - Real-user and PII beta readiness

| Field | Contract |
|---|---|
| Prerequisite PRs/gates | A2, P12-03, P13-05, P13-06, P13-07 |
| Prerequisite decisions | D-PHI-01, D-PHI-02 |
| Responsible owner | Luke |
| Verifier | External/TBD |

Acceptance matrix:

- ☐ A written B1 data-classification boundary limits the invitation-only US cohort to at most five IP/GC pairs and permits only the approved nonclinical PII fields.
- ☐ Medical, reproductive-health, psychological, insurance-health and clinical-clearance data, real document bytes and real provider packets are expressly prohibited; AI receives only de-identified nonclinical context.
- ☐ The exact release uses a NOBYPASSRLS non-owner runtime, FORCE RLS on every in-scope table, verified transaction-local context and passing pool-reset/cross-org/cross-resource negative tests.
- ☐ Named beta users, support/on-call, access review, incident response, backup/restore, retention/deletion and complaint routes are ready.
- ☐ Alan's technical evidence is current; external privacy/legal advice is recorded; there is no unresolved critical finding and any high exception is written, time-limited and externally reviewed.
- ☐ A2 evidence is current for the exact candidate revision and rollback/feature-disable controls are operational.
- ☐ Consent/privacy/terms copy is approved and data-subject correction/deletion workflows are testable.

Required evidence:

- Signed B1 checklist and five-pair cohort roster
- data inventory/classification and prohibited-data tests
- runtime/migrator grants and RLS policy matrix
- cross-org/pool-reset results
- de-identification evidence
- access review
- incident tabletop
- backup/restore result
- vendor register
- external privacy/legal advice
- current A2 bundle no older than 60 days

**Failure and rollback response.** No real-user invitation. Continue synthetic-only, close control gaps, invalidate stale evidence and re-run the exact affected reviews/tests before a new go/no-go.

### 1.3.6 Gate B2 - PHI readiness and formal go/no-go

| Field | Contract |
|---|---|
| Prerequisite PRs/gates | B1 |
| Prerequisite decisions | D-PHI-01, D-PHI-02 |
| Responsible owner | Luke |
| Verifier | External security/privacy/compliance reviewers |

Acceptance matrix:

- ☐ Formal PHI data flows, risk assessment, policies, BAAs/vendor controls, least privilege, audit/log retention, encryption/key management, incident/breach response and backup/restore are approved.
- ☐ Application, infrastructure, document, provider and intelligence threat models have current evidence and no unresolved critical/high risk without accepted exception.
- ☐ Operational staff training, access provisioning/deprovisioning, monitoring, support and emergency stop are complete.
- ☐ The exact release passed A2 and B1 revalidation; a signed human go/no-go records scope, date, evidence versions and approvers.
- ☐ Qualified external security, privacy/compliance and legal/vendor reviewers are named; release evidence is no older than 30 days and underlying assessments are no older than 12 months.
- ☐ No critical exception is open; any high exception has joint Luke and relevant external-reviewer approval.
- ☐ The gate states explicitly that testing/deployment alone did not establish HIPAA/PHI readiness.
- ☐ PHI-capable upload, provider and intelligence paths remain disabled until this signed approval; B1 controls are necessary but not sufficient.

Required evidence:

- Signed go/no-go
- risk/security/privacy assessments
- BAA/vendor evidence
- access/log/incident/backup controls
- penetration/security testing
- training/operations evidence
- current technical gate bundles

**Failure and rollback response.** PHI remains prohibited. Keep B1 PII scope only if still independently valid; disable any PHI-capable upload/context path, remediate, and repeat formal review.

## 1.4 Explicit PR sequence

| Order | ID | Title | Repository | Dependencies | Gate | Local preparation | Merge readiness |
|---|---|---|---|---|---|---|---|
| 1 | P13-01 | Expose known-revision health, readiness, and dependency diagnostics | app | P01-01 | A0 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P01-01; Luke review/final founder approval |
| 2 | P13-02 | Harden guarded deployment, rollback, and evidence capture | infra | P01-01, P13-01 | A0 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P01-01, P13-01; technical decisions/controls D-OPS-01; Luke review/final founder approval |
| 3 | P13-03 | Automate synthetic A1 core participant journey verification | app | P03-02, P04-03, P05-03, P11-03, P13-02 | A1 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P03-02, P04-03, P05-03, P11-03, P13-02; Gate A0 active and verified; Luke review/final founder approval |

| Order | ID | Title | Repository | Dependencies | Gate | Local preparation | Merge readiness |
|---|---|---|---|---|---|---|---|
| 4 | P13-04 | Automate synthetic A2 commercial and document journey verification | app | P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03 | A2 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03; Gate A0 active and verified; Luke review/final founder approval |
| 5 | P13-05 | Enforce case RLS and a non-owner PostgreSQL runtime | app | P02-03, P03-05, P04-03, P08-04, P09-05, P10-02 | B1 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P02-03, P03-05, P04-03, P08-04, P09-05, P10-02; Gate A0 active and verified; Luke review/final founder approval |
| 6 | P13-06 | Harden B1/B2 backups, audit, alarms, and cohort controls | infra | P09-02, P13-02, P13-05 | B1 | Not ready; named PR, decision or programme-acceptance prerequisites remain | Blocked pending PR dependencies P09-02, P13-02, P13-05; Gate A0 active and verified; Luke review/final founder approval |

| Order | ID | Title | Repository | Dependencies | Gate | Local preparation | Merge readiness |
|---|---|---|---|---|---|---|---|
| 7 | P13-07 | Publish B1 and B2 privacy, PHI, and operational go-no-go runbooks | .github | P13-04, P13-05, P13-06 | B1 | Evidence-structure preparation only; technical and external evidence remains incomplete | Blocked pending PR dependencies P13-04, P13-05, P13-06; Gate A0 active and verified; Luke review/final founder approval; qualified external attestations and B1 evidence |

### 1.4.1 P13-01 - Expose known-revision health, readiness, and dependency diagnostics

| Field | Plan |
|---|---|
| Repository / base | `app` (`main`) |
| Gate / size | A0 / Large |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P01-01; Luke review/final founder approval |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Dependencies | P01-01 |
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | Current /healthz, direct 503 evidence |

**1.4.1.1 Objective** Separate liveness, readiness, build revision, migration, database, intelligence, storage, and safe-config status so Gate A0 can identify the actual failing dependency.

#### 1.4.1.2 Scope

- Unauthenticated minimal liveness
- Safe readiness/dependency checks
- Revision/config identifiers without secrets
- Startup failure classification

#### 1.4.1.3 Explicit non-goals

- No PHI/PII in diagnostics
- No dependency mutation

#### 1.4.1.4 Expected files or modules

- `app/health.py`
- `app/main.py`
- `app/dev_diagnostics.py`
- `tests/python/test_health.py`

#### 1.4.1.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | Health/readiness endpoints with stable machine-readable reasons. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | No cloud/infrastructure resource or workflow change. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

**1.4.1.6 Tests and validation** Objective tests:

- DB/migration/intelligence/storage failures
- timeout
- redaction
- known SHA
- ALB contract

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

**1.4.1.7 Diagnostics and observability** Structured startup/readiness logs.

**1.4.1.8 Rollout** Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

#### 1.4.1.9 Rollback or forward repair

Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

#### 1.4.1.10 Dependencies and parallel work

Hard dependencies: P01-01. Parallel opportunities: P13-03, P13-04, P13-05, P13-06, P13-07

#### 1.4.1.11 Objective acceptance criteria

- ☐ Separate liveness, readiness, build revision, migration, database, intelligence, storage, and safe-config status so Gate A0 can identify the actual failing dependency.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.1.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | runtime operations, FastAPI, observability |
| Higher-capability review | Mandatory before merge |

### 1.4.2 P13-02 - Harden guarded deployment, rollback, and evidence capture

| Field | Plan |
|---|---|
| Repository / base | `infra` (`main`) |
| Gate / size | A0 / Large |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P01-01, P13-01; technical decisions/controls D-OPS-01; Luke review/final founder approval |
| Technical-decision owner | D-OPS-01: Alan - immediate recovery/rollback/forward-repair mechanism |
| Dependencies | P01-01, P13-01 |
| Blocking decisions/checkpoints | D-OPS-01 |

| Field | Plan |
|---|---|
| Source / salvage | Existing guarded app/infra workflows |

**1.4.2.1 Objective** Make app/intelligence deployment record the image SHA/task definition, wait for health, capture non-secret failure evidence, and roll back or stop safely under explicit guards.

#### 1.4.2.2 Scope

- Known-revision deploy and service stabilization
- Least-privilege one-off migration task identity
- Migration/app compatibility preflight
- Rollback/forward-repair decision
- Evidence artifact

#### 1.4.2.3 Explicit non-goals

- No automatic billable activation
- No planning-task deployment

#### 1.4.2.4 Expected files or modules

- `.github/workflows/cdk.yml`
- `lib/stacks/platform-stack.ts`
- `lib/constructs/migration-task.ts`
- `scripts/verify-service-health.*`
- `docs/runbooks/deploy-rollback.md`

#### 1.4.2.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | Guarded workflow/alarms/contracts; default desired counts remain safe. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

**1.4.2.6 Tests and validation** Objective tests:

- CDK/workflow contract

- unhealthy revision
- rollback compatibility
- billable flag false
- missing SSM output

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

**1.4.2.7 Diagnostics and observability** Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

**1.4.2.8 Rollout** Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

**1.4.2.9 Rollback or forward repair** Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

**1.4.2.10 Dependencies and parallel work** Hard dependencies: P01-01, P13-01. Parallel opportunities: P13-04, P13-05, P13-07

#### 1.4.2.11 Objective acceptance criteria

- ☐ Make app/intelligence deployment record the image SHA/task definition, wait for health, capture non-secret failure evidence, and roll back or stop safely under explicit guards.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.2.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | D-OPS-01: Alan - immediate recovery/rollback/forward-repair mechanism |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | AWS ECS/ALB, GitHub Actions, rollback operations |
| Higher-capability review | Mandatory before merge |

### 1.4.3 P13-03 - Automate synthetic A1 core participant journey verification

| Field | Plan |
|---|---|
| Repository / base | `app` (`main`) |
| Gate / size | A1 / Large |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P03-02, P04-03, P05-03, P11-03, P13-02; Gate A0 active and verified; Luke review/final founder approval |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Dependencies | P03-02, P04-03, P05-03, P11-03, P13-02 |
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | Existing synthetic sandbox/scenario utilities |

**1.4.3.1 Objective** Run the entry, auth, Node 0 Free, low-risk GC claim, role separation, resume, and mobile journey against a known dev revision and publish a redacted A1 evidence bundle.

#### 1.4.3.2 Scope

- A1 core IP/GC workspace journey
- Known SHA and evidence bundle
- Role/authorization negative cases
- Cleanup of synthetic records

#### 1.4.3.3 Explicit non-goals

- No payment/promotion/document journey
- No real user
- No PHI
- No gate auto-approval

#### 1.4.3.4 Expected files or modules

- `tests/cloud/a1/`
- `scripts/run_synthetic_a1.py`
- `.github/workflows/synthetic-cloud-gates.yml`
- `docs/runbooks/synthetic-gates.md`

#### 1.4.3.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | Manual/guarded A1 synthetic runner with immutable artifact summary. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

**1.4.3.6 Tests and validation** Objective tests:

- Happy path
- authorization denial
- retry/duplicate
- logout/login
- mobile
- dependency outage
- cleanup failure

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

**1.4.3.7 Diagnostics and observability** Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

**1.4.3.8 Rollout** Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

**1.4.3.9 Rollback or forward repair** Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

**1.4.3.10 Dependencies and parallel work** Hard dependencies: P03-02, P04-03, P05-03, P11-03, P13-02. Parallel opportunities: P13-01, P13-05, P13-06, P13-07

#### 1.4.3.11 Objective acceptance criteria

- ☐ Run the entry, auth, Node 0 Free, low-risk GC claim, role separation, resume, and mobile journey against a known dev revision and publish a redacted A1 evidence bundle.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.3.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | browser automation, AWS dev operations, end-to-end testing |
| Higher-capability review | Mandatory before merge |

### 1.4.4 P13-04 - Automate synthetic A2 commercial and document journey verification

| Field | Plan |
|---|---|
| Repository / base | `app` (`main`) |
| Gate / size | A2 / Exceptional |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03; Gate A0 active and verified; Luke review/final founder approval |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Dependencies | P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03 |

| Field | Plan |
|---|---|
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | Payment document smoke paths, A1 harness |

**1.4.4.1 Objective** Extend the known-revision cloud harness with commitment, funding, exactly-once promotion, case invite, activation, billing, refund, document, handoff, Ask/Learn, and recovery evidence.

#### 1.4.4.2 Scope

- A2 commercial/promotion/billing/document journey
- Duplicate/retry/refund/failure cases
- Known SHA and evidence bundle
- Synthetic cleanup

#### 1.4.4.3 Explicit non-goals

- No real money
- No real user
- No PHI
- No gate auto-approval

#### 1.4.4.4 Expected files or modules

- `tests/cloud/a2/`
- `scripts/run_synthetic_a2.py`
- `.github/workflows/synthetic-cloud-gates.yml`
- `docs/runbooks/synthetic-gates.md`

#### 1.4.4.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | Guarded A2 synthetic runner; uses processor simulator and synthetic documents only. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

#### 1.4.4.6 Tests and validation

Objective tests:

- Funding event exactly once
- promotion replay
- case invite
- milestone/refund
- upload/scan failure
- Ask scope
- rollback evidence

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

#### 1.4.4.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

#### 1.4.4.8 Rollout

Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

#### 1.4.4.9 Rollback or forward repair

Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

#### 1.4.4.10 Dependencies and parallel work

Hard dependencies: P06-03, P07-04, P08-04, P09-05, P10-04, P12-02, P13-03. Parallel opportunities: P13-01, P13-02, P13-05, P13-06

#### 1.4.4.11 Objective acceptance criteria

- ☐ Extend the known-revision cloud harness with commitment, funding, exactly-once promotion, case invite, activation, billing, refund, document, handoff, Ask/Learn, and recovery evidence.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.4.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | None; implement the settled founder constraints and approved contracts |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | browser automation, payments testing, AWS dev operations, end-to-end testing |
| Higher-capability review | Mandatory before merge |

### 1.4.5 P13-05 - Enforce case RLS and a non-owner PostgreSQL runtime

| Field | Plan |
|---|---|
| Repository / base | `app` (`main`) |
| Gate / size | B1 / Exceptional |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P02-03, P03-05, P04-03, P08-04, P09-05, P10-02; Gate A0 active and verified; Luke review/final founder approval |
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval |
| Dependencies | P02-03, P03-05, P04-03, P08-04, P09-05, P10-02 |
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | case-shell.md current app-layer-only/RLS gap, Wave 2 unguarded document/reviewer loaders |

**1.4.5.1 Objective** Move app runtime to a least-privilege non-DDL database role and enforce organization/resource access policies with RLS/FORCE RLS before any real-user PII gate can open.

#### 1.4.5.2 Scope

- Runtime/migrator role separation with NOBYPASSRLS and runtime DML only
- RLS/FORCE RLS on workspace/case/participant/access/document/work-item/commercial/private-memory tables
- Transaction-local verified subject/org/resource/purpose context
- Organization-scoped staff capabilities
- Policy-negative and pool-reset tests

#### 1.4.5.3 Explicit non-goals

- No PHI gate activation

- No trust in app guards alone
- No runtime DDL

#### 1.4.5.4 Expected files or modules

- `migrations/versions/*_case_rls.py`
- `app/storage/connection.py`
- `app/storage/session_context.py`
- `tests/security/test_case_rls.py`
- `docs/security/rls.md`

#### 1.4.5.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | RLS policies and least-privilege grants under a reviewed migration. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | No cloud/infrastructure resource or workflow change. |
| Migration/backfill | Apply through the named versioned migration; no ad-hoc startup DDL. Backfill is none unless explicitly listed in scope. |
| Security/privacy | Database denies cross-case/ambient reads even if an app guard is missed. |
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

**1.4.5.6 Tests and validation** Objective tests:

- Unset context denies
- cross-org/case/owner/role denial
- staff queue organization scope
- connection-pool context reset
- migrator versus runtime grants
- background worker scope
- previous app compatibility during rollout

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **B1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

**1.4.5.7 Diagnostics and observability** Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

**1.4.5.8 Rollout** Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

**1.4.5.9 Rollback or forward repair** Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

**1.4.5.10 Dependencies and parallel work** Hard dependencies: P02-03, P03-05, P04-03, P08-04, P09-05, P10-02. Parallel opportunities: P13-01, P13-02, P13-03, P13-04

#### 1.4.5.11 Objective acceptance criteria

- ☐ Move app runtime to a least-privilege non-DDL database role and enforce organization/resource access policies with RLS/FORCE RLS before any real-user PII gate can open.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.5.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | PostgreSQL RLS, connection pooling, security architecture |
| Higher-capability review | Mandatory before merge |

### 1.4.6 P13-06 - Harden B1/B2 backups, audit, alarms, and cohort controls

| Field | Plan |
|---|---|
| Repository / base | `infra` (`main`) |
| Gate / size | B1 / Exceptional |
| Local preparation status | Not ready; named PR, decision or programme-acceptance prerequisites remain |
| Merge readiness | Blocked pending PR dependencies P09-02, P13-02, P13-05; Gate A0 active and verified; Luke review/final founder approval |

| Field | Plan |
|---|---|
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations |
| Dependencies | P09-02, P13-02, P13-05 |
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | Existing audit/backup/platform stack constructs |

**1.4.6.1 Objective** Add the infrastructure evidence and controls required for a named PII beta and later PHI review: backup/restore, data-event audit, least privilege, alarms, log retention, cohort disable, and emergency stop.

#### 1.4.6.2 Scope

- RDS/S3 backup and restore evidence hooks
- CloudTrail S3 data events and access alarms
- Runtime/migrator/task-role least privilege
- Cohort disable and PHI gate kill switch
- Log retention/redaction contracts

#### 1.4.6.3 Explicit non-goals

- No production/PHI activation
- No evidence claim without restore/tabletop

#### 1.4.6.4 Expected files or modules

- `lib/stacks/platform-stack.ts`
- `lib/constructs/audit.ts`
- `lib/constructs/backup.ts`
- `test/security-controls.test.ts`
- `docs/runbooks/security-operations.md`

#### 1.4.6.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | Guarded, cost-aware controls with explicit dev defaults and documented operational owners. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |

| Area | Planned change |
|---|---|
| Architecture/docs/config | Document the contract, version pins and safe partial-merge behavior. |

#### 1.4.6.6 Tests and validation

Objective tests:

- CDK policy assertions
- restore drill
- alarm path
- access-log redaction
- cohort/PHI gate disable
- role boundary

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **B1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

#### 1.4.6.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

#### 1.4.6.8 Rollout

Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

#### 1.4.6.9 Rollback or forward repair

Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

#### 1.4.6.10 Dependencies and parallel work

Hard dependencies: P09-02, P13-02, P13-05. Parallel opportunities: P13-01, P13-03, P13-04

#### 1.4.6.11 Objective acceptance criteria

- ☐ Add the infrastructure evidence and controls required for a named PII beta and later PHI review: backup/restore, data-event audit, least privilege, alarms, log retention, cohort disable, and emergency stop.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.

- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.6.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Alan (proposed; pending Alan review) |
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations |
| Reviewer | Luke |
| Final approver | Luke |
| PR-level ownership exception | None |
| Required expertise | AWS security, backup/restore, CloudTrail/CloudWatch, IAM |
| Higher-capability review | Mandatory before merge |

### 1.4.7 P13-07 - Publish B1 and B2 privacy, PHI, and operational go-no-go runbooks

| Field | Plan |
|---|---|
| Repository / base | `.github` (`main`) |
| Gate / size | B1 / Large |
| Local preparation status | Evidence-structure preparation only; technical and external evidence remains incomplete |
| Merge readiness | Blocked pending PR dependencies P13-04, P13-05, P13-06; Gate A0 active and verified; Luke review/final founder approval; qualified external attestations and B1 evidence |
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations |
| Dependencies | P13-04, P13-05, P13-06 |
| Blocking decisions/checkpoints | None beyond dependencies and plan approval |
| Source / salvage | Natalyx compliance/company records by reference, all gate evidence |

**1.4.7.1 Objective** Create the programme evidence index and explicit human approval packets for PII beta (B1) and PHI readiness (B2), linking rather than duplicating controlled company/compliance records.

#### 1.4.7.2 Scope

- Data classification and real-user boundary
- Access/logging/incident/backup/vendor/compliance evidence
- Named approvers and expiry/revalidation
- Rollback/stop response

#### 1.4.7.3 Explicit non-goals

- No legal/compliance self-certification
- No PHI activation by merge

#### 1.4.7.4 Expected files or modules

- `natalyx-repair-program/gates/B1-real-user-pii.md`
- `natalyx-repair-program/gates/B2-phi-go-no-go.md`
- `natalyx-repair-program/evidence-index.md`

#### 1.4.7.5 Change map

| Area | Planned change |
|---|---|
| Schema/model | None in this PR; any later schema change stays in its named migration PR. |
| API/routes | No public API/route contract change. |
| UI/product surface | No visible participant/operator UI change. |
| Infrastructure/workflow | No cloud/infrastructure resource or workflow change. |
| Migration/backfill | No migration or backfill. |
| Security/privacy | Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases. |
| Architecture/docs/config | Controlled go/no-go checklists and evidence links only. |

**1.4.7.6 Tests and validation** Objective tests:

- Evidence completeness review
- tabletop incident
- access review
- backup/restore evidence
- external security/privacy sign-off

Local validation:

- `git diff --check`
- `python scripts/validate_programme.py`

Cloud validation: run only through Gate **B1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

**1.4.7.7 Diagnostics and observability** Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

**1.4.7.8 Rollout** Merge only after document/sign-off checks; it changes no runtime. Regenerate the Drive review package from the same canonical data; reactivate tracking only after approval.

**1.4.7.9 Rollback or forward repair** Correct the canonical data and regenerate; do not rewrite implementation history.

**1.4.7.10 Dependencies and parallel work** Hard dependencies: P13-04, P13-05, P13-06. Parallel opportunities: P13-01, P13-02, P13-03

#### 1.4.7.11 Objective acceptance criteria

- ☐ Create the programme evidence index and explicit human approval packets for PII beta (B1) and PHI readiness (B2), linking rather than duplicating controlled company/compliance records.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

#### 1.4.7.12 Ownership and review

| Role | Recommendation |
|---|---|
| Work-package DRI | Alan |
| Primary implementer | Joint (proposed; pending Alan review) |
| Technical-decision owner | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations |
| Reviewer | Luke + External/TBD |
| Final approver | Luke |
| PR-level ownership exception | Alan assembles technical control evidence; Luke owns founder go/no-go; qualified external reviewers supply required attestations. |
| Required expertise | privacy/security governance, operations, compliance |
| Higher-capability review | Mandatory before merge |

## 1.5 Cross-repository coordination

| Repository | Authority after merge |
|---|---|
| `.github` | programme/governance evidence and future approved tracking |
| `app` | routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain |

| Repository | Authority after merge |
|---|---|
| `infra` | AWS resources, IAM/KMS/network/deployment/backup/audit contracts |

Merge order inside this package: `P13-01` → `P13-02` → `P13-03` → `P13-05` → `P13-04` → `P13-06` → `P13-07`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

## 1.6 Test and acceptance matrix

| Test dimension | Method | Objective result |
|---|---|---|
| Happy path | Known revision; ALB/ECS/dependency health; Rollback; Synthetic A1/A2; PII controls; PHI go/no-go evidence | Expected state/event/UI and named evidence are produced once. |
| Authorization failure | Wrong/no subject, role, membership, purpose or consent | 403/404 as appropriate; no write or data leak; audit safe failure. |
| Role differences | Separate IP, GC, operator, provider/service identities | Only the approved lens/projection/actions appear. |
| Retries/duplicates | Repeat same canonical request/event | Original result returned; no duplicate membership/case/invoice/document/event. |
| Concurrency | Two writers/claimants/migrators/workers | One valid transition; loser receives deterministic stale/conflict response. |
| Stale state | Old revision/config/terms/token/artifact | Fail closed or approved compatibility behavior; never silent coercion. |
| Malformed input | Boundary, encoding, size, enum, redirect and identifier corpus | Validation before side effects; safe error. |
| Unavailable dependency | Database, intelligence, processor, S3/scanner or auth unavailable | Explicit degraded/blocked behavior; no hallucinated success. |
| Partial failure | Crash between external effect, DB transaction and outbox | Retry/forward repair converges from durable evidence. |
| Logout/login/resume | Session expires/restarts mid-flow | Return to authorized current state; no query/link authority. |
| Mobile/accessibility | 320/375/768 widths, keyboard, focus, reduced motion | Core task completes with truthful state and no clipped controls. |
| Synthetic cloud | Known dev revision and synthetic identities/data | Gate artifact records SHA, dependency status, audit and cleanup. |

| Test dimension | Method | Objective result |
|---|---|---|
| Audit/observability | Inspect events/metrics/logs | Versions, actor/authority, correlation and reason present; no sensitive payload. |

## 1.7 Risks and decisions

Founder outcomes, Alan's remaining technical ownership and external activation dependencies are recorded separately so a final policy is never mistaken for an active control.

| ID | Status | Classification | Remaining owner | Affected / latest | Programme effect |
|---|---|---|---|---|---|
| D-AUTH-03 | Resolved by reconciliation | Reconciliation settled | Alan - implementation | P03-02, P03-03, P03-05, P04-01, P04-02, P09-04, P13-05; Resolved 2026-07-12 | No longer blocks the reconciled access/workspace PR sequence. |
| D-OPS-01 | Founder constraints final; Alan immediate; operationally pending | Luke sets constraints; Alan decides immediately | Alan - immediate | P13-02; Before Gate A0 recovery action | P13-02 and Gate A0 remain blocked until the runbook and synthetic exercise pass; A1 must exercise the control. |
| D-PHI-01 | Founder beta scope final; externally gated | Luke decides beta scope; external evidence required | Alan - B1/B2 evidence; external reviewers - approval | P09-01, P09-02, P09-05, P09-06, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI | B1 remains blocked until the limited PII control bundle is accepted; real documents/provider packets and all PHI remain blocked until B2. |
| D-PHI-02 | Founder governance final; external reviewers pending | Luke decides governance; external evidence required | Alan - evidence; external reviewers - attestations; Luke - go/no-go | P13-06, P13-07; Before B1 | B1 and B2 remain blocked until the corresponding evidence is current and the required humans sign off. |

### 1.7.1 D-AUTH-03 - Identity, participation and access authorization contract

| Field | Recorded decision or requirement |
|---|---|
| Decision state | Final |

| Field | Recorded decision or requirement |
|---|---|
| Founder outcome | Identity, participation, access grants, ownership and operation authorization remain separate; participation or lens alone never authorizes. |
| Founder constraints | Subject-derived authorization context; Application and RLS policy parity; Default-deny cross-resource access |
| What remains for Alan | Encode the settled contract in application services and RLS |
| Evidence required | Participation-without-grant and grant-without-capability denials; Application/RLS parity tests |
| Approval rule | No further founder decision unless the boundary changes. |
| External dependencies | None |
| Affected PRs / latest point | P03-02, P03-03, P03-05, P04-01, P04-02, P09-04, P13-05; Resolved 2026-07-12 |
| Programme effect | No longer blocks the reconciled access/workspace PR sequence. |
| Independent recommendation | Identity binds principal to person; participation records domain relationship; grants carry resource-scoped capabilities; application and RLS consume a subject-derived context plus ownership and purpose. Participation/lens alone never authorizes. |

### 1.7.2 D-OPS-01 - Known-good recovery revision and rollback sequence

| Field | Recorded decision or requirement |
|---|---|
| Decision state | Final founder constraints |
| Founder outcome | Use fail-closed recovery: protect data integrity over uptime, restore only a reviewed proven-compatible application-image/schema pair, use safe read-only or unavailability when uncertain, and forward-repair when rollback is unsafe. Target 30-minute beta recovery; allow up to two hours emergency downtime and notify Luke when more than one hour is expected. |
| Founder constraints | Zero intended loss or corruption; No expensive 24/7 coverage for synthetic/early controlled beta without evidence; Real-user, destructive or uncertain-loss recovery requires explicit human approval |
| What remains for Alan | Choose exact compatibility, rollback/forward-repair and automation mechanisms; Name the evidence owner and write the runbook |
| Evidence required | Documented recovery procedure; Successful synthetic recovery exercise; Known-compatible image/schema evidence |
| Approval rule | Luke accepts A0 evidence and explicitly approves risky real-user/destructive recovery. |

| Field | Recorded decision or requirement |
|---|---|
| External dependencies | None |
| Affected PRs / latest point | P13-02; Before Gate A0 recovery action |
| Programme effect | P13-02 and Gate A0 remain blocked until the runbook and synthetic exercise pass; A1 must exercise the control. |
| Independent recommendation | Use a tested immutable image and compatible schema; do not deploy from dirty or draft branches. |

### 1.7.3 D-PHI-01 - PII/PHI boundary, vendors and control set

| Field | Recorded decision or requirement |
|---|---|
| Decision state | Final founder scope; externally dependent activation |
| Founder outcome | B1 is an invitation-only US beta of at most five IP/GC pairs using names, verified account/contact data, relationship/outreach/logistics, consent versions, nonclinical progress, feedback and processor references only. Medical, reproductive-health, psychological, insurance-health and clinical-clearance data are prohibited; no real document bytes or provider packets; AI receives de-identified nonclinical context only. |
| Founder constraints | RLS/non-owner runtime and cross-tenant negative evidence; Access review plus incident and restore exercises; No PHI before B2 |
| What remains for Alan | Implement inventory, cohort controls, RLS, cross-tenant denials, de-identification and prohibited-data tests |
| Evidence required | Five-pair cohort configuration; RLS/cross-tenant/de-identification/prohibited-data tests; External privacy/legal approval |
| Approval rule | Luke accepts B1 only after required evidence and external privacy/legal advice; B2 requires qualified external approval. |
| External dependencies | External privacy/legal approval before B1; Qualified external security/privacy/compliance/legal approval before B2 |
| Affected PRs / latest point | P09-01, P09-02, P09-05, P09-06, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI |
| Programme effect | B1 remains blocked until the limited PII control bundle is accepted; real documents/provider packets and all PHI remain blocked until B2. |
| Independent recommendation | B1 remains PII-only and content controls stay synthetic; B2 requires formal external security/privacy/compliance evidence before any PHI content path is enabled. |

### 1.7.4 D-PHI-02 - B1/B2 approvers and evidence expiry

| Field | Recorded decision or requirement |
|---|---|
| Decision state | Final founder governance; externally dependent activation |
| Founder outcome | Luke accepts B1 from Alan's technical evidence plus external privacy/legal advice, without separate independent technical sign-off. B1 evidence is at most 60 days old and reruns after material change or 180 days. B2 requires qualified external security, privacy/compliance and legal/vendor review with release evidence at most 30 days old and assessments at most 12 months old. |
| Founder constraints | No critical exceptions; High B1 exceptions are written, time-limited and externally reviewed; High B2 exceptions require joint Luke and relevant external approval |
| What remains for Alan | Maintain evidence recency, change-triggered reruns and exception records |
| Evidence required | B1/B2 evidence index with dates; Named reviewers; Exception register; Signed go/no-go |
| Approval rule | Luke is final product go/no-go within the specified external-review model. |
| External dependencies | Named privacy/legal advisers for B1; Named qualified security/privacy/compliance/legal reviewers for B2 |
| Affected PRs / latest point | P13-06, P13-07; Before B1 |
| Programme effect | B1 and B2 remain blocked until the corresponding evidence is current and the required humans sign off. |
| Independent recommendation | Luke is product go/no-go; independent qualified reviewers own their control attestations. |

| Implementation risk | Owner | Treatment |
|---|---|---|
| Unknown running revision | Alan | Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate. |
| Rollback incompatible with schema | Alan | Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate. |
| Synthetic success overclaimed | Alan | Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate. |
| PHI enabled without organizational controls | Alan | Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate. |

## 1.8 Existing-work salvage

| Source | Head | Valuable content | Destination | Recommendation | Extraction status/safety |
|---|---|---|---|---|---|
| feat/byos-journey-wave-2 | 5b63e3a7c364 | Projection-driven phase-1 cluster presentation, exact route allowlisting, person-versus-case-side ownership intent, transactional submission/work-item and review/audit patterns, fail-closed item retention, approved Learn status selection and 36 focused tests. | P13-05 | Preserve paused at the exact head; selectively port semantics/tests only after adaptation. Do not merge, cherry-pick, continue implementation or use its runtime schema directly. | Paused exact-head evidence; no direct merge |

Package source inventory:

- Existing guarded AWS workflows and SSM contracts
- Current healthz
- Prior app/infra/intelligence AWS migration PR evidence

## 1.9 Ownership recommendation

Alan owns technical recovery/validation; Luke accepts gates and PHI boundary. External security, privacy, compliance, finance/payment, and clinical/legal review as applicable.

| PR | WP DRI | Primary implementer | Technical-decision owner | Reviewer | Final approver | Exception |
|---|---|---|---|---|---|---|
| P13-01 | Alan | Alan (proposed) | None; implement the settled founder constraints and approved contracts | Luke | Luke | None |
| P13-02 | Alan | Alan (proposed) | D-OPS-01: Alan - immediate recovery/rollback/forward-repair mechanism | Luke | Luke | None |
| P13-03 | Alan | Alan (proposed) | None; implement the settled founder constraints and approved contracts | Luke | Luke | None |
| P13-04 | Alan | Alan (proposed) | None; implement the settled founder constraints and approved contracts | Luke | Luke | None |
| P13-05 | Alan | Alan (proposed) | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval | Luke | Luke | None |

| PR | WP DRI | Primary implementer | Technical-decision owner | Reviewer | Final approver | Exception |
|---|---|---|---|---|---|---|
| P13-06 | Alan | Alan (proposed) | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations | Luke | Luke | None |
| P13-07 | Alan | Joint (proposed) | D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval; D-PHI-02: Alan - evidence index; qualified external reviewers - attestations | Luke + External/TBD | Luke | Alan assembles technical control evidence; Luke owns founder go/no-go; qualified external reviewers supply required attestations. |

PR ownership inherits the proposed work-package split pending Alan's review. Named technical-decision ownership remains separate and never transfers implementation ownership across work packages; reciprocal and external review requirements remain intact.

## 1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is

fail-closed or explicitly degraded.

- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.